

Active Directory

Implementing Group Policy to Control User Environment

Date: 28th April 2026

Prepared by: Seth Aboagye

1. Executive Summary

This report documents the end-to-end implementation of Group Policy Objects (GPOs) within the contoso.com Active Directory environment to enforce organizational security baselines, automate software deployment, and demonstrate policy inheritance hierarchies. The implementation aligns with defense-in-depth principles and establishes a foundation for compliance frameworks including CIS benchmarks, PCI-DSS, and SOC 2.

- Key Achievements:
- Enforced password complexity and account lockout policies for the Sales organizational unit.
- Deployed Notepad++ v8.9 via GPO software installation using an Assigned deployment method.
- Implemented removable storage access controls to block USB read/write operations.
- Demonstrated granular policy inheritance by creating a sub-OU (Sales-Managers) and applying user-rights assignments specific to management personnel.

2. Environment Overview

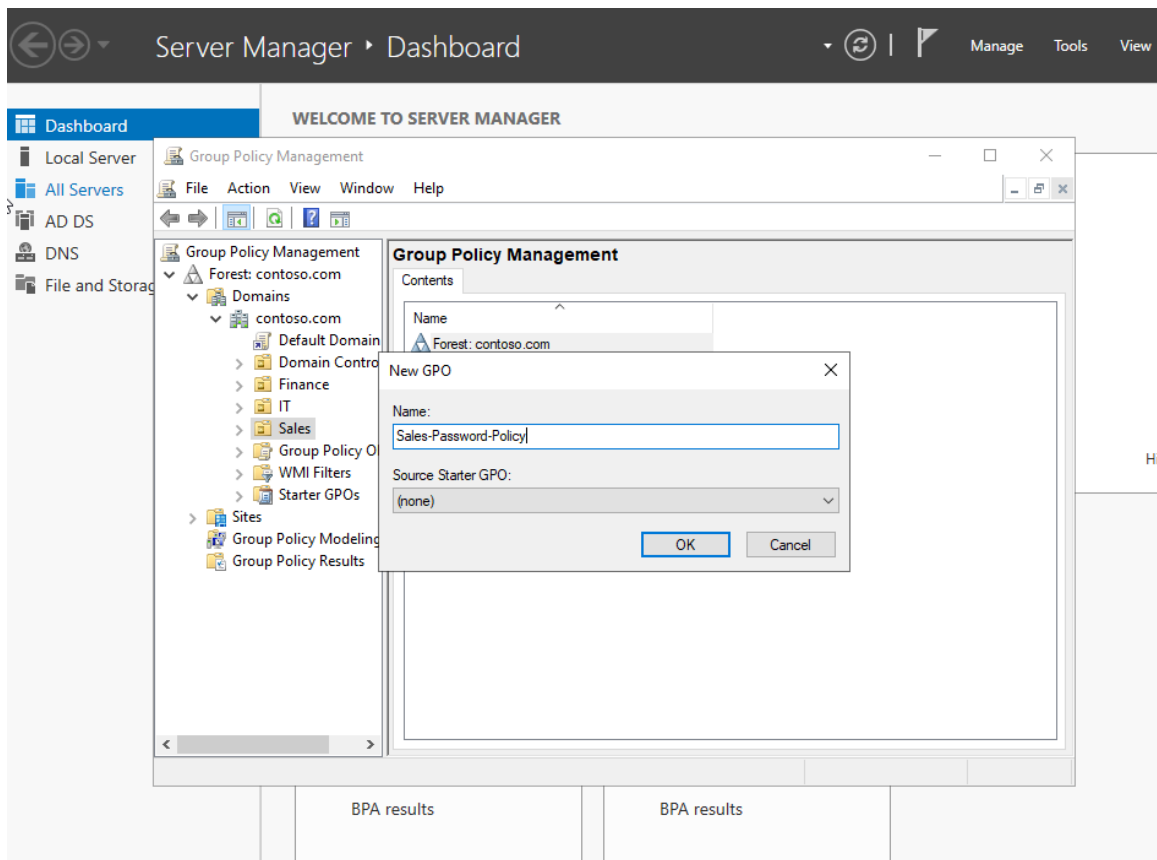
Asset	Role	OS / Details
DC01	Domain Controller	Windows Server (contoso.com)
WS01	Domain-Joined Workstation	Windows 10/11 (Member of Sales OU)
jdoe	Test User Account	Domain user, member of Sales department

Pre-Implementation Checks: Prior to GPO deployment, replication health was verified on DC01 using repadmin /replsummary to ensure directory consistency across the domain. On WS01, a baseline Group Policy Result report was generated via gpresult /h report.html to document the pre-change policy state, security group memberships, and applied GPOs.

3. Phase 1: Password Policy Enforcement

3.1 GPO Creation and Linking

A new Group Policy Object named Sales-Password-Policy was created and linked directly to the Sales OU in the Group Policy Management Console (GPMC). Linking the GPO at the OU level ensures the policy applies only to authorized users and computers within the Sales department, following the principle of least privilege.



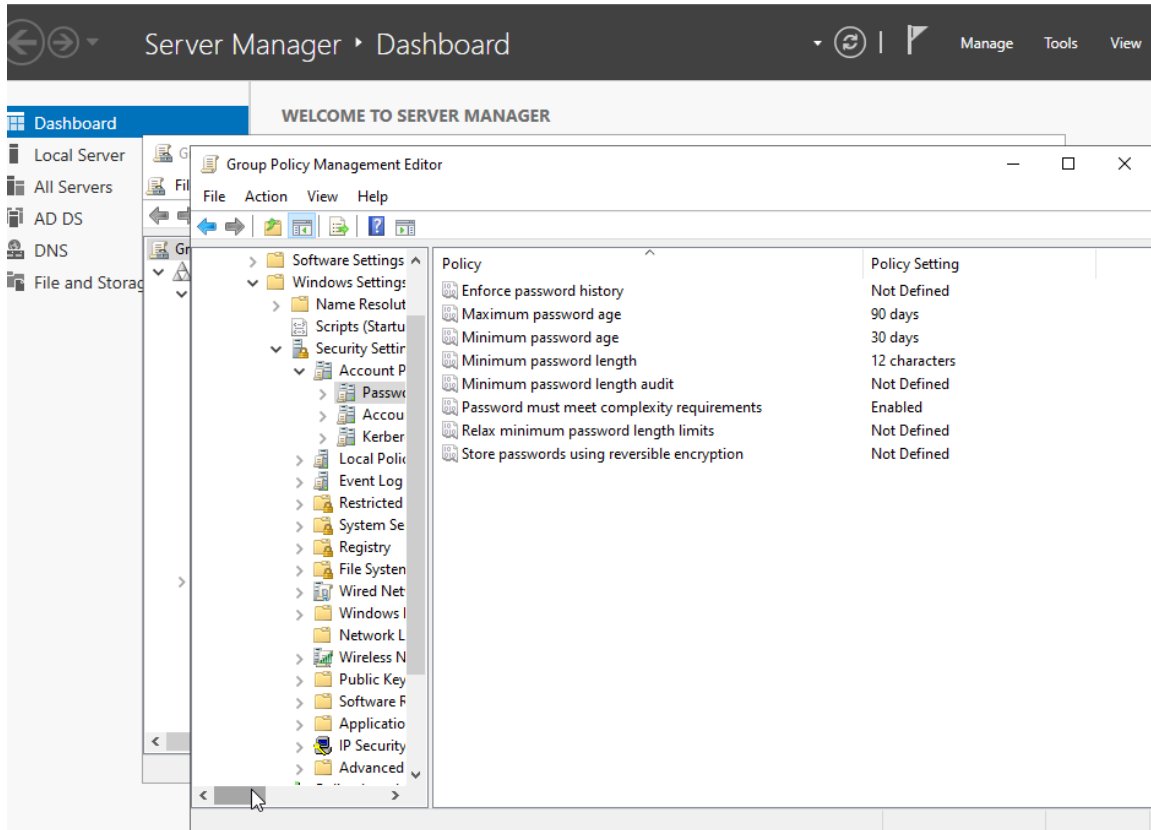
3.2 Policy Configuration

The GPO was edited to enforce hardened password standards under the following path:

Computer Configuration → Policies → Windows Settings → Security Settings → Account Policies → Password Policy

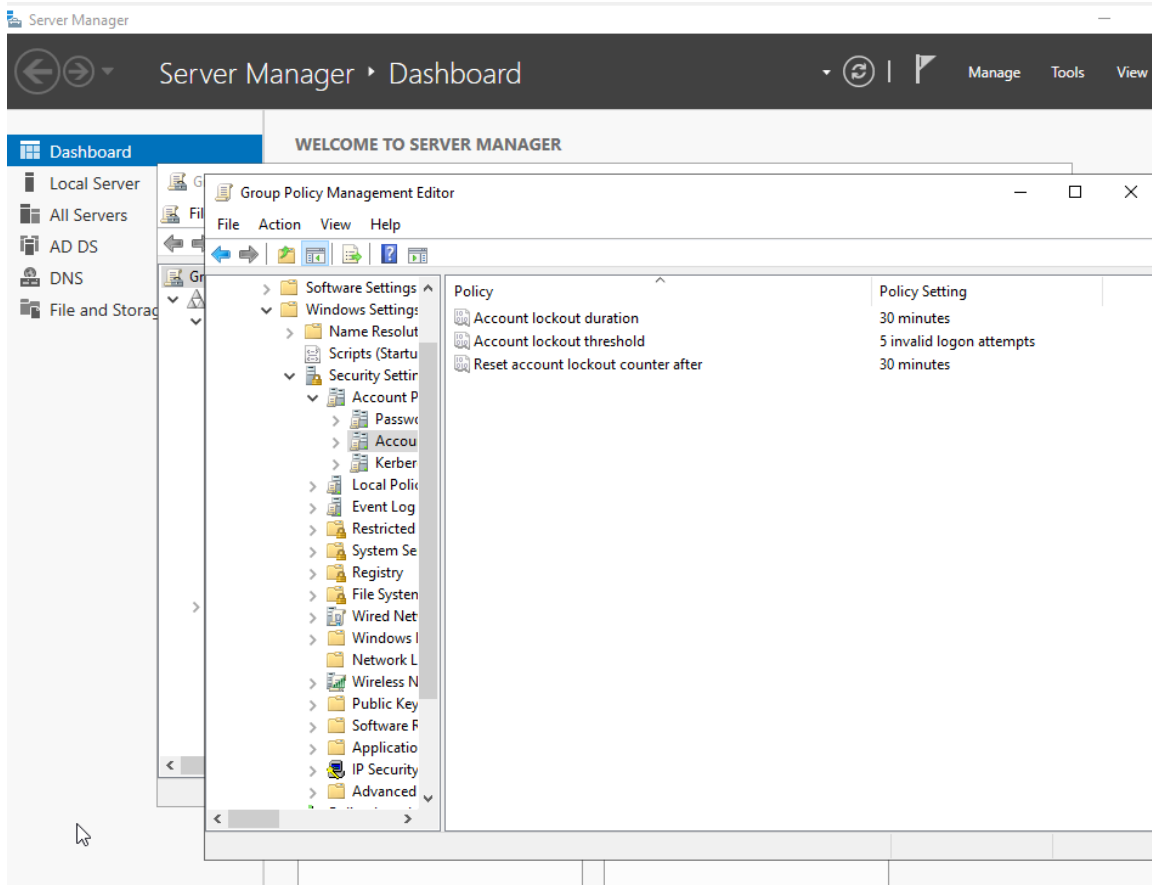
Configured Settings:

- Minimum password length: 12 characters
- Maximum password age: 90 days
- Password must meet complexity requirements: Enabled



Additionally, account lockout parameters were configured under Account Policies → Account Lockout Policy:

- Account lockout duration: 30 minutes
- Account lockout threshold: 5 invalid logon attempts
- Reset account lockout counter after: 30 minutes



3.3 Testing and Validation

On the target workstation WS01, policies were force-refreshed to bypass the default 90-minute replication window:

`gpupdate /force`

```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.
```

Negative Control Test:

An attempt to set a weak password (WealPass) for user jdoe was performed. As expected, the operation failed with error NET HELPMSG 2245, confirming that the new complexity and length requirements were active.

```
C:\Windows\system32>net user jdoe WealPass /domain
The request will be processed at a domain controller for domain contoso.com.

The password does not meet the password policy requirements. Check the minimum password length, password complexity
password history requirements.

More help is available by typing NET HELPMSG 2245.
```

Positive Control Test:

A complex password (P@ssPassword1) meeting the 12-character minimum and complexity requirements was then applied. The command completed successfully, validating that legitimate strong passwords are accepted under the new policy.

```
C:\Windows\system32>net user jdoe P@ssPassword1 /domain
The request will be processed at a domain controller for domain contoso.com.

The command completed successfully.

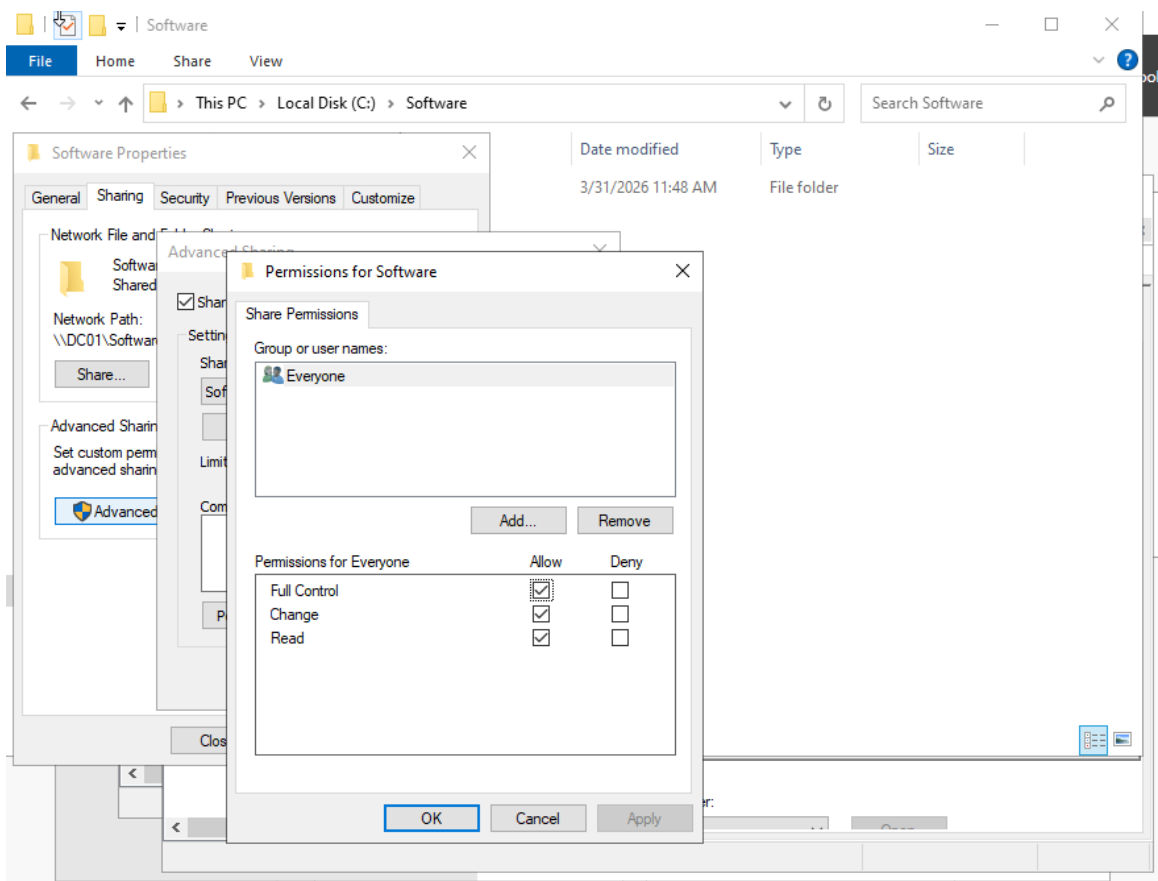
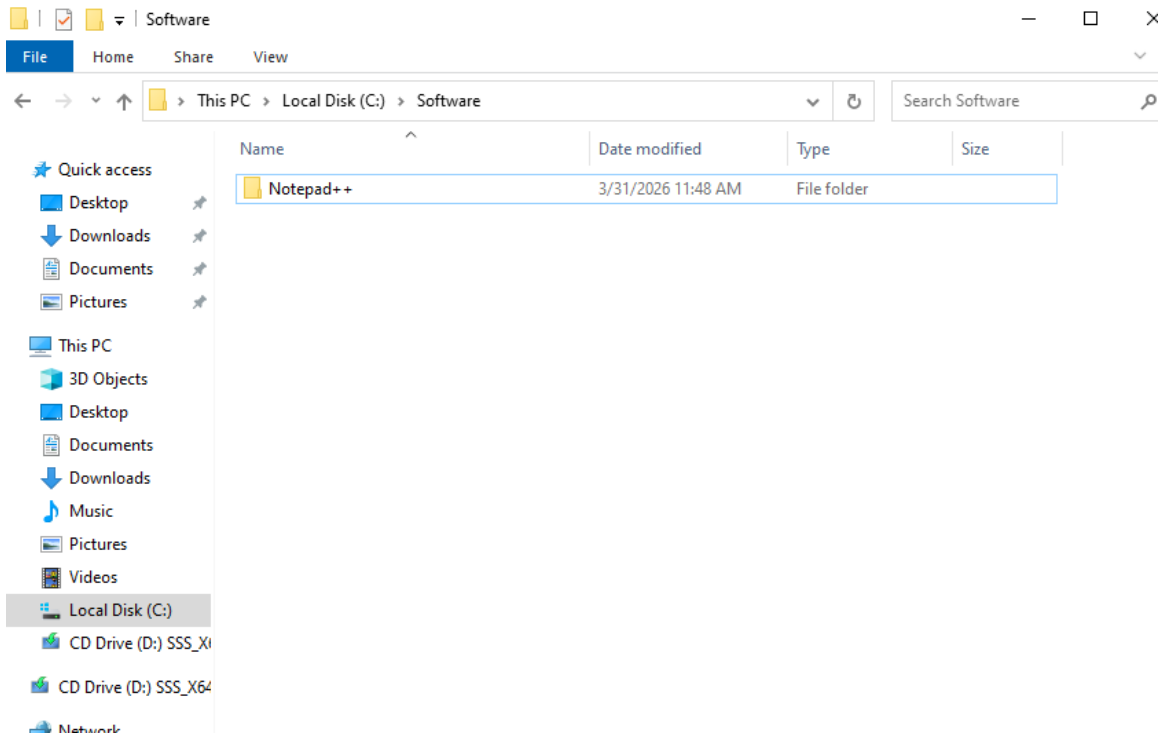
C:\Windows\system32>_
```

4. Phase 2: Software Deployment via GPO

4.1 Preparation of Software Distribution Point

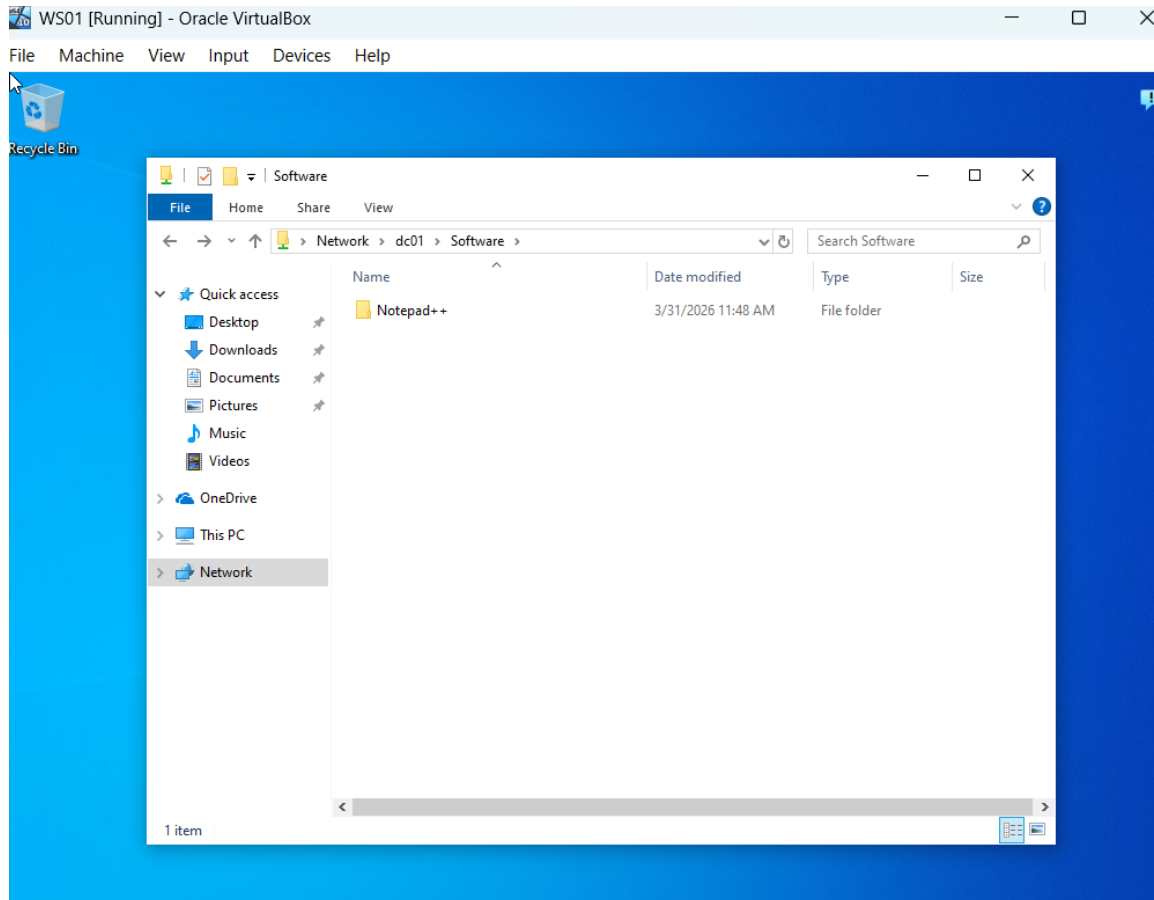
A central software repository was established on DC01 to host the deployment package:

- Local Path: C:\Software\Notepad++
- Network Share: \DC01\Software
- Permissions: The Software folder was shared with Everyone granted Full Control (acceptable for isolated lab environments; production environments should restrict this to Domain Computers and Authenticated Users with Read/Execute only).



4.2 Accessibility Verification

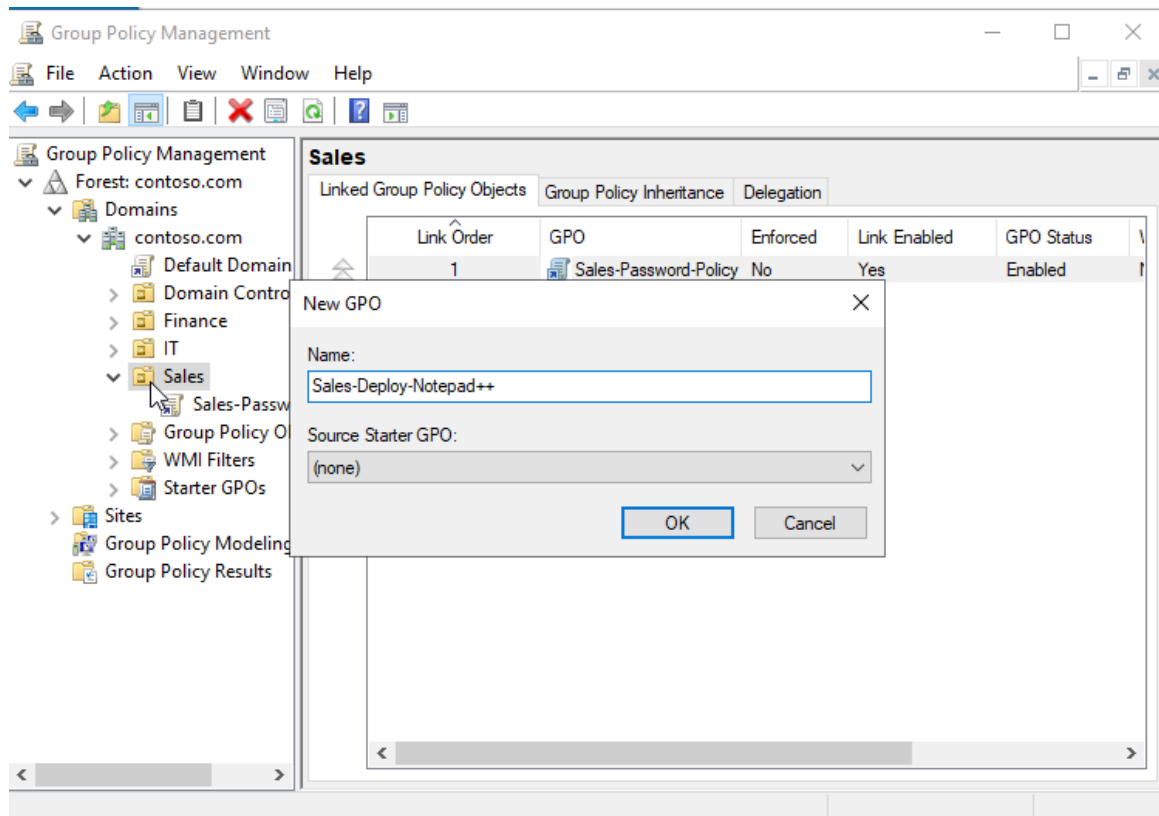
From WS01, network connectivity and share accessibility were confirmed by browsing to \\dc01\\Software. The Notepad++ folder was visible and accessible, validating the distribution point configuration before GPO assignment.



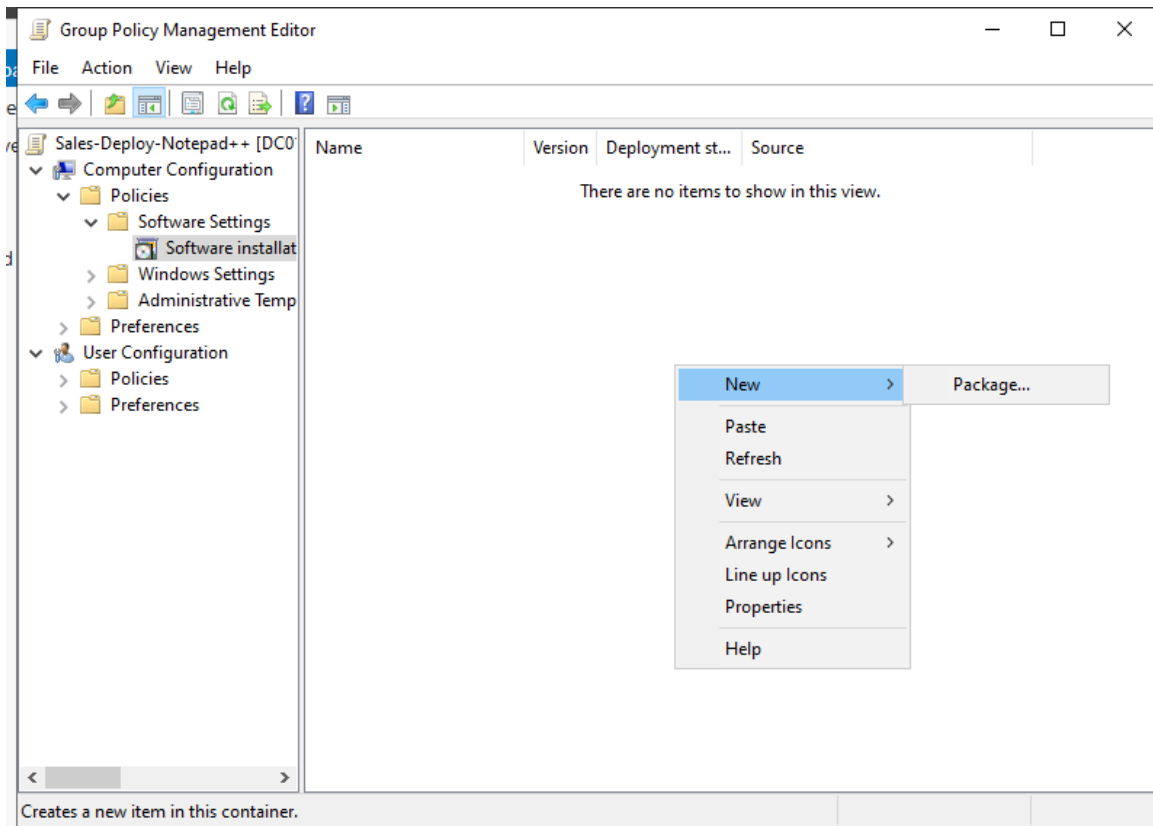
4.3 Deployment GPO Configuration

A new GPO named Sales-Deploy-Notepad++ was created and linked to the Sales OU. Within the Group Policy Management Editor, the software package was added under:

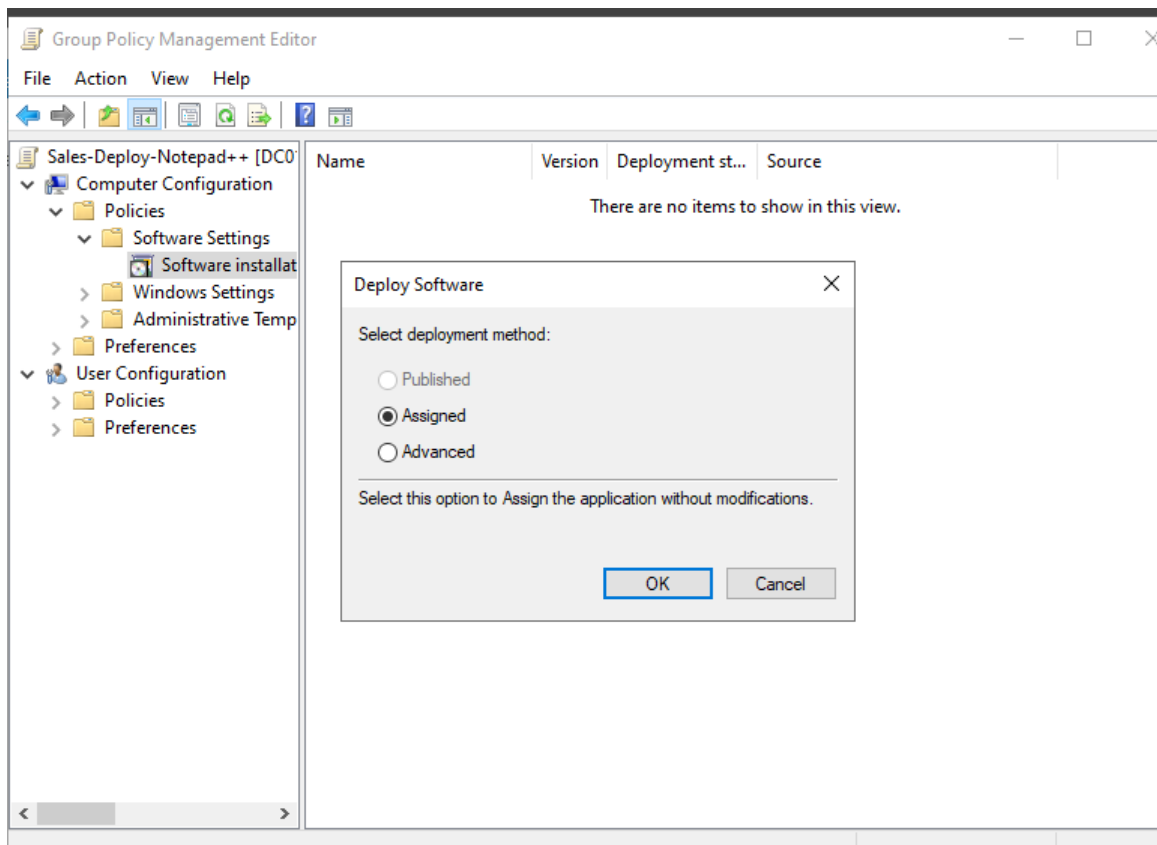
Computer Configuration → Policies → Software Settings → Software Installation



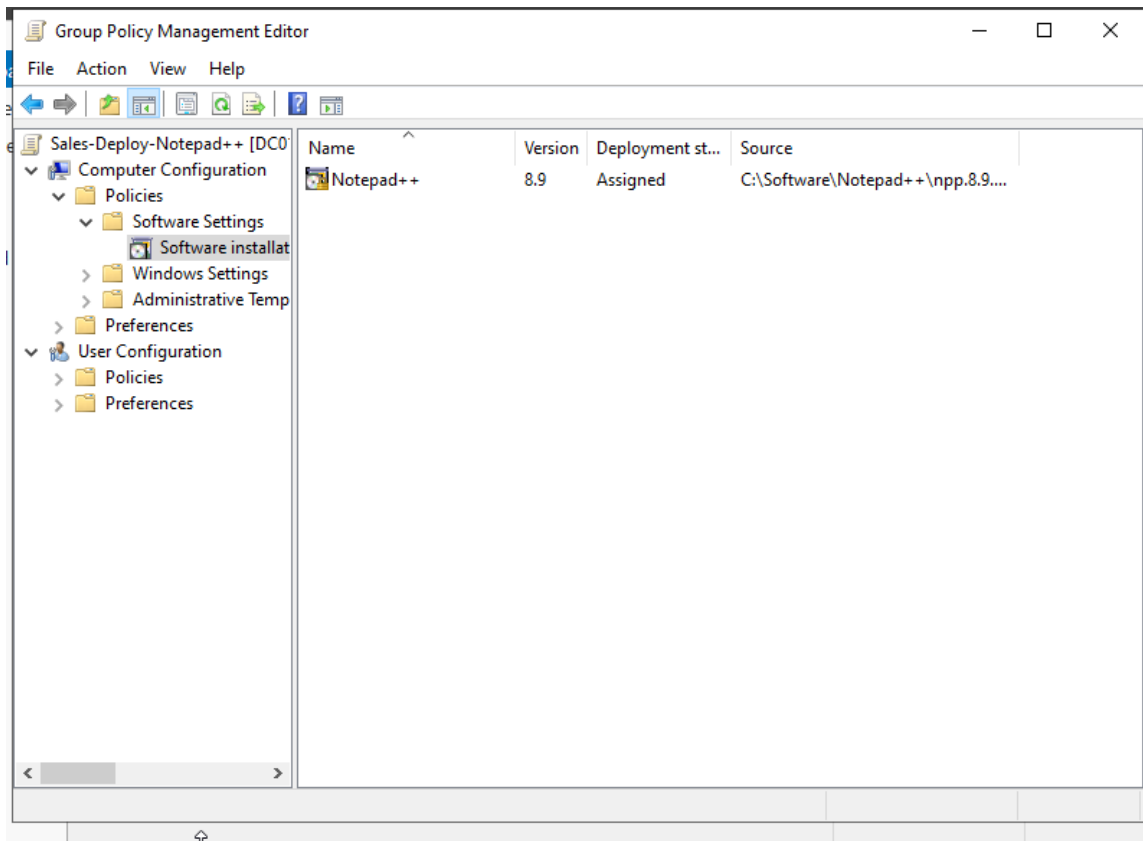
A new package was created by right-clicking Software Installation and selecting New → Package.



The deployment method was set to Assigned, which ensures automatic, silent installation during computer startup. Users cannot cancel or uninstall the application, providing administrative control over the software baseline.



The package successfully appeared in the GPO with the following metadata: Name: Notepad++, Version: 8.9, Deployment State: Assigned, Source: C:\Software\Notepad++\npp.8.9...



4.4 Client-Side Policy Refresh

To trigger immediate evaluation, gpupdate /force was executed on WS01.

```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.

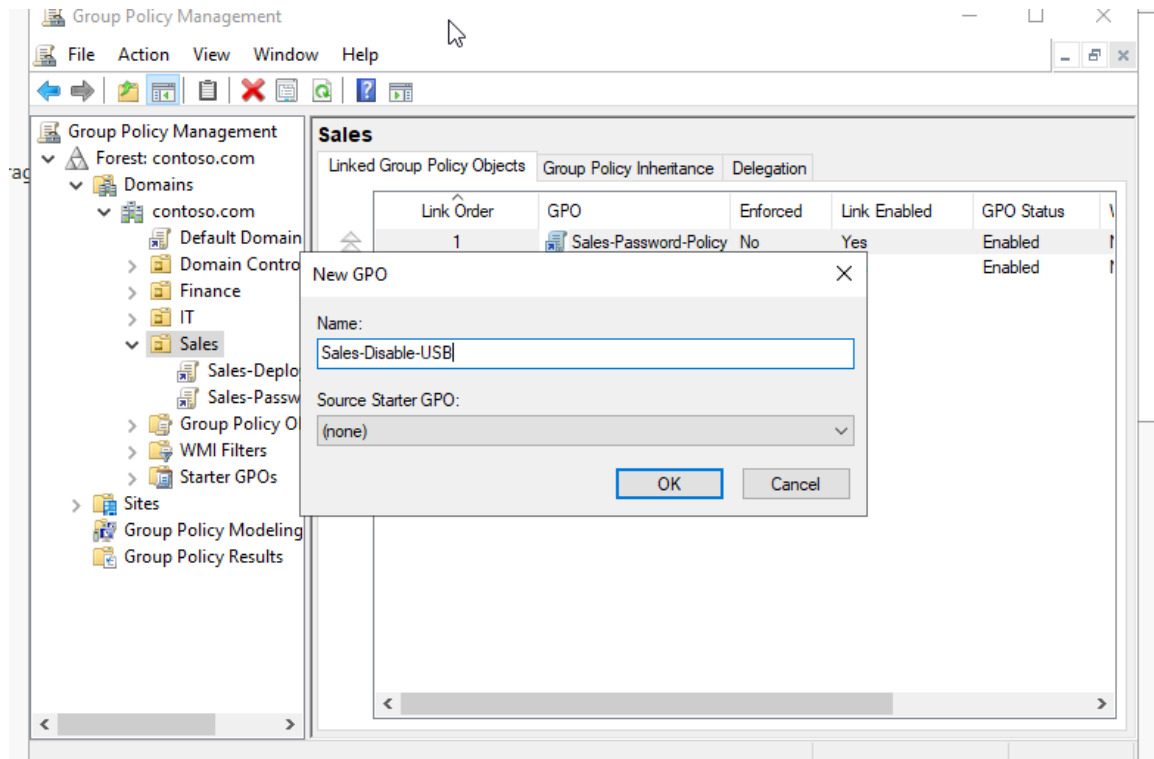
C:\Windows\system32>
```

Note: A reboot of WS01 would be required for the Assigned software installation to complete during the computer startup sequence.

5. Phase 3: Removable Storage Lockdown

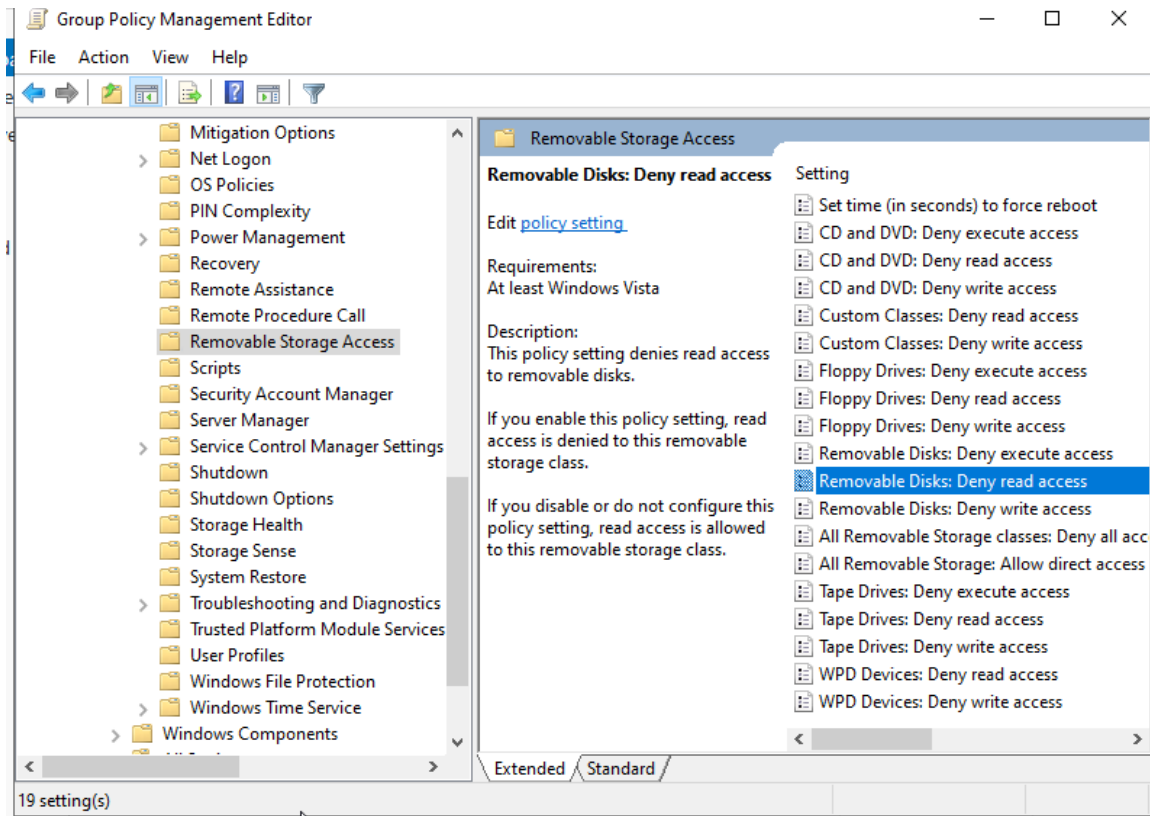
5.1 USB Restriction GPO

To mitigate data exfiltration risks and malware propagation via removable media, a security-focused GPO named Sales-Disable-USB was created and linked to the Sales OU.



5.2 Policy Settings

The following policies were configured under: Computer Configuration → Policies → Administrative Templates → System → Removable Storage Access



[Screenshot: 16.administrative_policies_for_removable_disks.png]

Enabled Policies:

- Removable Disks: Deny read access – Enabled

Removable Disks: Deny read access

Removable Disks: Deny read access Previous Setting Next Setting

☐ Not Configured Comment:

☒ Enabled

☐ Disabled

Supported on: At least Windows Vista

Options: Help:

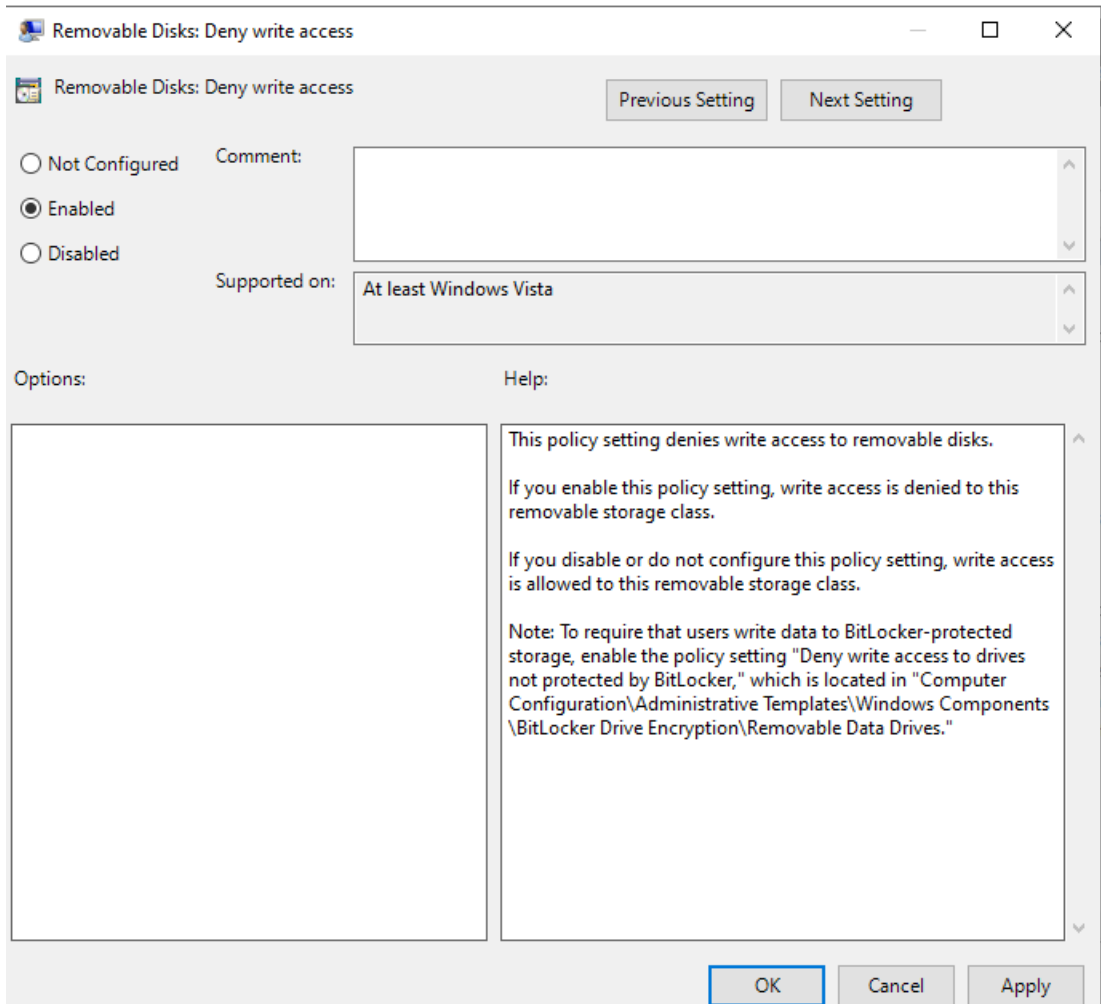
This policy setting denies read access to removable disks.

If you enable this policy setting, read access is denied to this removable storage class.

If you disable or do not configure this policy setting, read access is allowed to this removable storage class.

OK Cancel Apply

- Removable Disks: Deny write access – Enabled



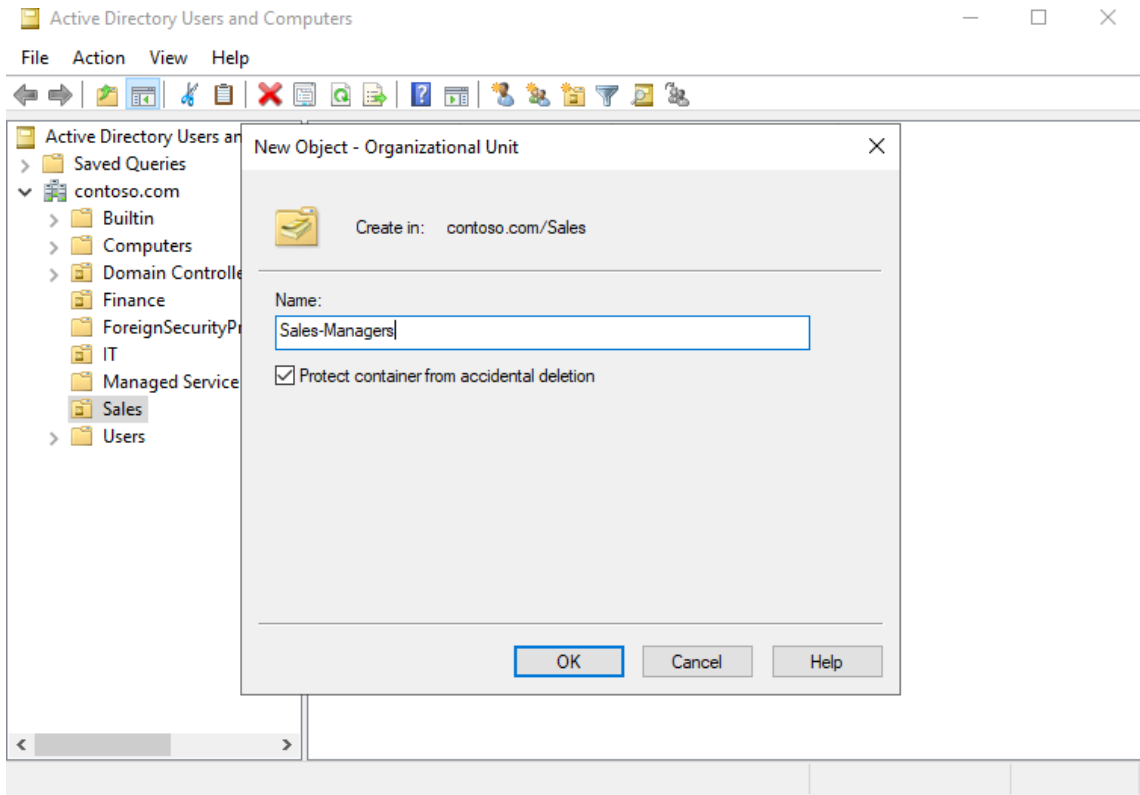
5.3 Operational Impact

Once applied and refreshed on WS01 (followed by a reboot), any USB removable disk inserted into the workstation will receive an Access Denied message for both read and write operations. This control is critical for environments handling sensitive data and is a standard recommendation in CIS Windows benchmarks.

6. Phase 4: Policy Inheritance and OU Hierarchy

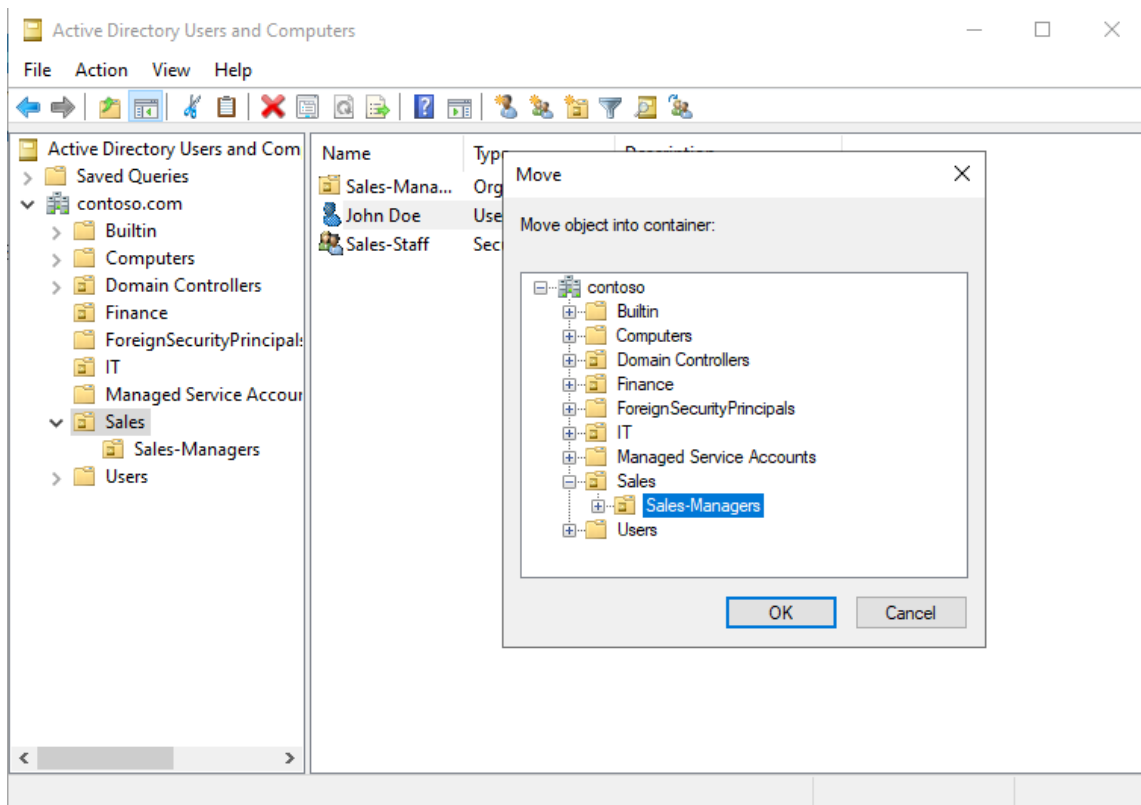
6.1 Sub-OU Creation

To demonstrate granular policy inheritance and scoped administrative rights, a child Organizational Unit named Sales-Managers was created under the Sales OU.



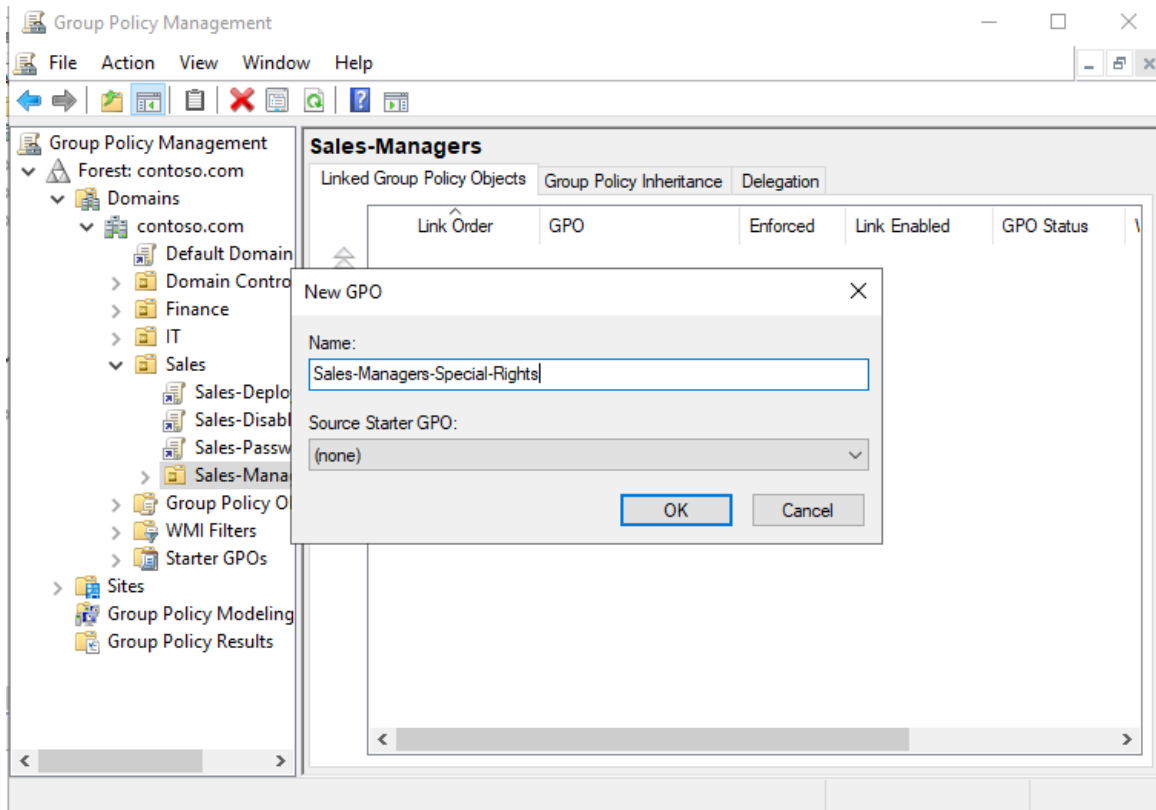
6.2 User Object Relocation

The user account `jdoe` (John Doe) was moved from the parent Sales OU into the Sales-Managers sub-OU. This relocation ensures that `jdoe` inherits all policies applied to Sales while becoming subject to additional manager-specific policies.



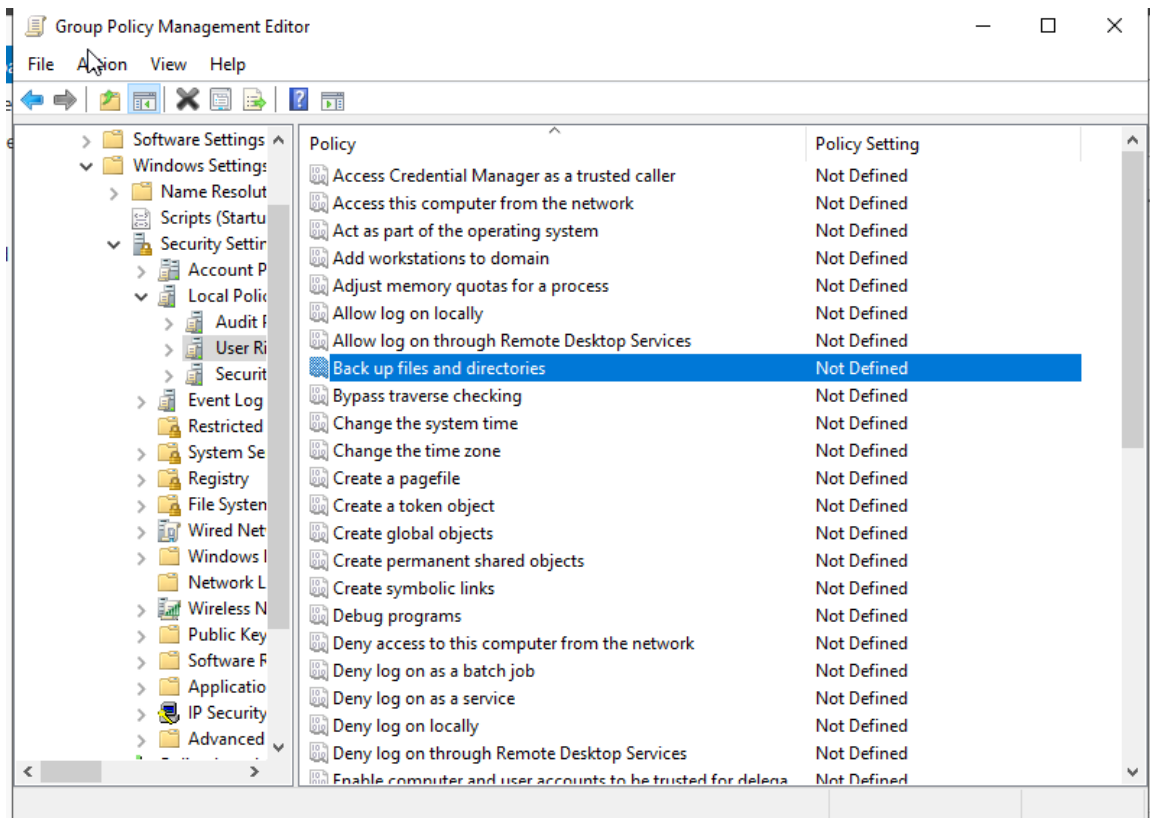
6.3 Manager-Specific Rights GPO

A new GPO named Sales-Managers-Special-Rights was created and linked exclusively to the Sales-Managers OU.

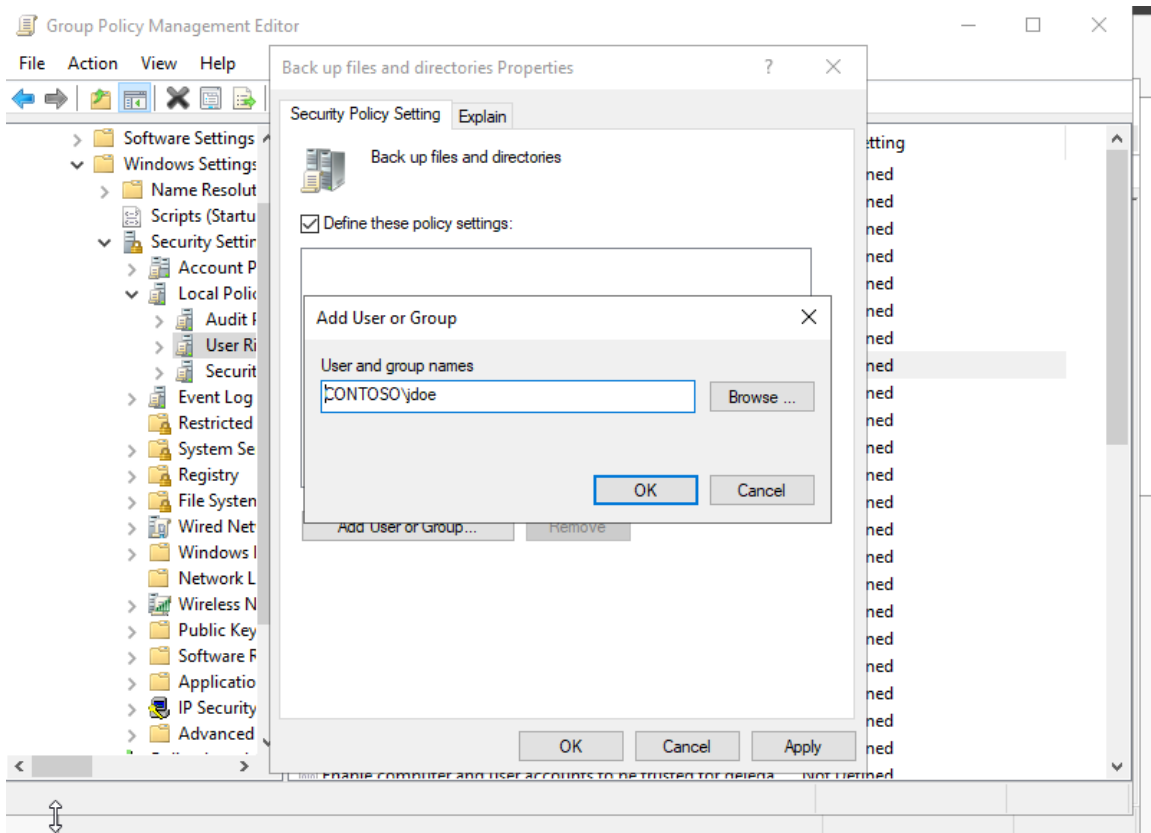


6.4 User Rights Assignment

Within the GPO editor, the following path was navigated: Computer Configuration → Policies → Windows Settings → Security Settings → Local Policies → User Rights Assignment. The policy "Back up files and directories" was configured.

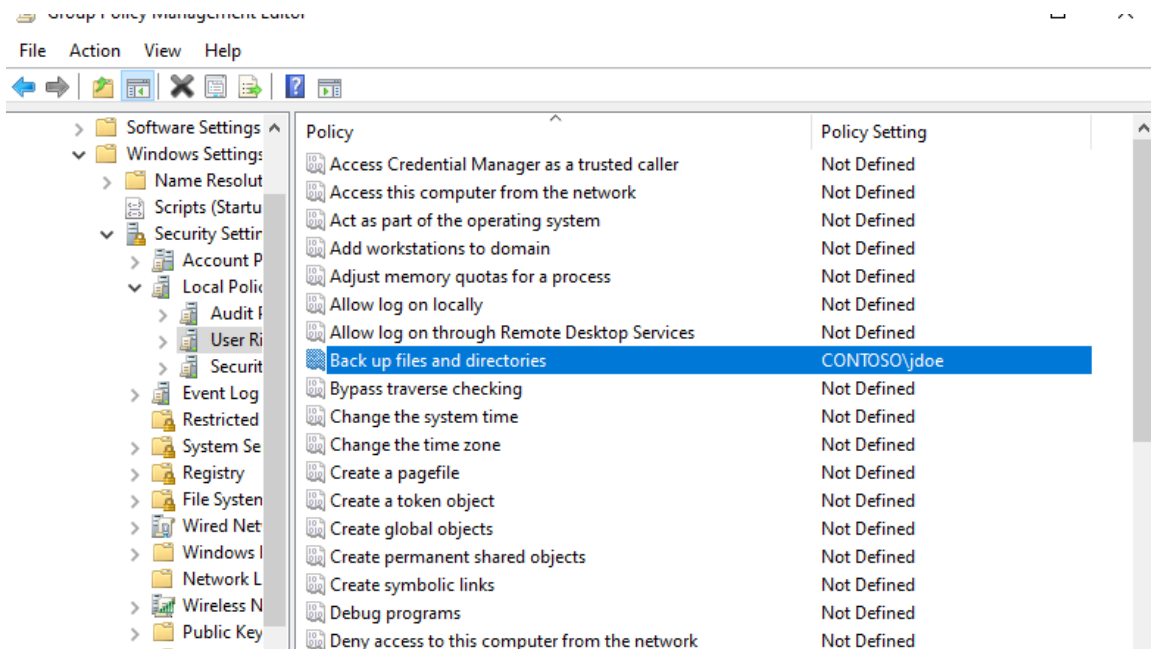


User CONTOSO\jdoe was explicitly added to the security policy setting.



6.5 Resulting Configuration

The policy now shows CONTOSO\jdoe as the defined principal for the "Back up files and directories" right. Regular sales staff remaining in the parent Sales OU do not receive this privilege, demonstrating how sub-OUs enable role-based access control (RBAC) through Group Policy.



7. Policy Application Order and Inheritance Analysis

Group Policy processing follows the LSDOU sequence: Local → Site → Domain → Organizational Unit. In this environment, the effective policy set for jdoe (now in Sales-Managers) is determined by the following hierarchy:

Order	GPO Name	Linked To	Scope
1	Default Domain Policy	contoso.com (Root)	Domain-wide baseline
2	Sales-Password-Policy	Sales OU	Password & lockout rules
3	Sales-Deploy-Notepad++	Sales OU	Software installation
4	Sales-Disable-USB	Sales OU	Removable media restrictions
5	Sales-Managers-Special-Rights	Sales-Managers (Sub-OU)	Backup privileges for jdoe

Inheritance Behavior: Policies 1–4 apply to all users and computers within the Sales OU and its children. Policy 5 applies only to objects within Sales-Managers. If a conflict existed between the parent and child GPOs, the child OU's GPO would win by default (unless Enforced or Block Inheritance is configured—neither was applied here).

8. Security and Compliance Relevance

Control Domain	GPO Implementation	Framework Mapping
Identity & Access Management	Password complexity (12 chars, 90-day expiry)	CIS Control 4, PCI-DSS 8.2.3
Endpoint Protection	USB read/write denial	CIS Control 10, NIST 800-53 MP-7
Configuration Management	Automated software deployment	CIS Control 2, SOC 2 CC7.1
Privilege Management	Scoped user rights via sub-OU	CIS Control 6, NIST 800-53 AC-6

Threat Mitigation:

- Credential attacks: Account lockout and complexity requirements reduce brute-force and spray attack success rates.
- Insider threat / data loss: USB restrictions prevent unauthorized data exfiltration to removable media.
- Malware: Controlled software deployment ensures only approved applications are installed, reducing the attack surface.
- Privilege escalation: Granular user rights prevent standard users from obtaining backup-level access unless explicitly authorized.

9. Recommendations for Production Hardening

1. Share Permissions: Replace Everyone with Domain Computers and Authenticated Users on the \DC01\Software share, granting only Read & Execute rights.
2. GPO Delegation: Restrict edit rights on security-sensitive GPOs (e.g., Sales-Disable-USB) to the Domain Admins group to prevent tampering.
3. Audit Policy: Enable advanced audit policies to log GPO modifications, failed logon attempts, and removable storage access attempts.
4. WMI Filtering: Consider applying software deployment GPOs only to specific OS versions or machine types using WMI filters.
5. Backup: Regularly back up GPOs using Backup-GPO PowerShell cmdlets or the GPMC backup functionality.

10. Conclusion

The Group Policy implementation was successfully completed across all four phases. Security baselines for password hygiene, software standardization, and removable media control are now enforced for the Sales department. The sub-OU hierarchy demonstrates how organizations can scale GPO administration to support role-based privileges without compromising the

integrity of parent-level policies. All configurations were tested and verified on WS01, confirming operational effectiveness.

Status: Implementation Complete

Next Review: 90 days (aligned with maximum password age policy)

End of Report